

Athens, 18-11-2024

No. Protocol: 3211

DECISION 42/2024

The Hellenic Data Protection Authority convened at the invitation of its President in a meeting on Tuesday, 28-07-2023, at 10:00 a.m. and in a second meeting on Tuesday, 19-12-2023, at 10:00 a.m., in order to examine the case referred to in the background of this document. Present were the President of the Authority, Konstantinos Menoudakos, the regular members Spyridon Vlachopoulos, Konstantinos Lamprinoudakis, Charalampos Anthopoulos, Aikaterini Iliadou, Grigorios Tsolias, and Christos Kalloniatis, as rapporteur. Present, without voting rights, were Ioannis Lykotrafitis, special scientist - computer scientist, Stefania Plota, special scientist - lawyer, as assistants to the rapporteur, and Irini Papageorgopoulou, employee of the administrative affairs department, as secretary.

The Authority took into account the following:

With his request No. G/ΕΙΣ/6282/20-04-2022, A addressed the Hellenic Data Protection Authority (hereinafter "the Authority") submitting the question of how he can oppose, as an escort of a member of the Vouliagmeni Nautical Club (hereinafter "N.O.B." or "the Club"), the processing of his biometric data, of which he was informed by N.O.B. via email. According to this notification, the controlled entry-exit system would no longer be conducted by presenting the member's escort card to a guard at the entrance, but by processing his biometric characteristics, without further information or justification for this measure.

2

The above question, interpreted either as a request for information for the exercise of a subject's right, or as a question regarding the legality of processing, falls outside the Authority's jurisdiction. However, due to the importance of the matter, the Authority deemed it necessary to take action ex officio and, with its letter No. G/ΕΞΕ/1226/20-05-2022, taking into account the updated Operating Regulation of the club, which, as it had been posted on its website (last checked 19-05-2022), states in provision 2.1 the following: "For the entry of Members (main and protected) to N.O.B., biometric characteristics are used. After their registration in the biometric characteristics system, plastic cards are canceled. On the first visit of the member and their family to the Club, a brief visit to the N.O.B. Secretariat is required for the registration of the member in the system," called on N.O.B. to provide clarifications regarding the processing of biometric data for controlling the entry of its members to the Club, including, among other things, the legal basis and other characteristics of the intended processing, as well as whether an impact assessment study of the effects of the processing on the protection of personal data had been conducted.

N.O.B., with its letter No. G/ΕΙΣ/7663/02-06-2022, responded to the Authority that "...until recently, only the entry system using an individual magnetic card for each member was used, which also bore the photograph of each member's face. Today, an entry system is used with an individual card for each member, which also bears the photograph of the face, and is identified by presenting an identity card or other public identification document. Recently, a parallel identification system has also been used, which is based on the geometry of the face, which is unique for each person. Therefore, the coordinates of each person's face are processed by a very advanced algorithm, which creates a code for each individual similar to what would be on an RFID card." Specifically regarding the technical specifications of this new system, N.O.B. states that "the biometric authentic devices of ZKTeco, which concern access control and time attendance, comply with personal data regulations, meaning that the biometric data of their users belong to them, because they are...

3

appropriately secured and stored using encryption methods within the devices.... With ZKTeco Time Attendance or Access Control systems, images are never stored. Photos are taken and distinct features known as data points are collected from the image. A studied algorithm is used to convert the data into a biometric template in the form of digital code. ZKTeco Biometric Algorithms and Templates: As an additional security measure, the biometric template is then encrypted, and the certification

process takes place on ZK's palm and facial recognition machines, which occurs within the devices without external factors. The necessary data is compared with the terminal data, and the result of the comparison is extracted. The result of the comparison is stored locally and sent to the client via the SSL/TSL encryption algorithm. The encryption algorithm for the data sent is random. The result is a system that provides the highest level of protection for biometric data, ensuring compliance with personal data GDPR. Biometric templates can only be recognized by the ZKTeco algorithm and cannot be converted into biometric images outside of this algorithm. ZKTeco Biometric templates cannot be recognized by other biometric algorithms." Regarding the legal basis for processing, N.O.B. states that: "In this case, the legality of processing under Article 6 paragraph 1 GDPR and the exceptions of Article 9 paragraph 2 GDPR applies, if it is considered that it concerns sensitive personal data," emphasizing that primarily the legal basis for the intended processing is based on Article 6 paragraph 1 GDPR, specifically in subparagraphs a, b, c, d, e, and further that the exception for processing based on Article 9, in subparagraphs a, b, c, and d, is permissible. Finally, N.O.B. states that its members and athletes, upon registration, have provided their explicit consent for the processing of their personal data, which is freely revocable, meaning that each member is entitled, at any time, to enter the Club with the concurrently valid alternative entry method (identification with a personal card) and that "it is a primary duty and right, vital interest, statutory and legal obligation of the Club, to ensure a safe and healthy environment for our members and athletes within our facilities. This is primarily achieved by excluding third parties who, for example, have stolen the entry card, have forged it, have borrowed it from an active member, etc. The absolutely correct identification of those entering the Club is our primary responsibility and obligation, given that both through our statutes, the sports law, and the Civil Code, we have a corresponding obligation, and it is our duty to provide those entitled to enter with the safest and healthiest environment. This takes into account that for many hours of the day, the majority of those entering consist of minors, for whose health and integrity their parents have entrusted the Club and the absolutely controlled environment of its facilities. Access control to the Club's facilities is the first and last line of defense against would-be thieves, pickpockets, exhibitionists, rapists, pedophiles, kidnappers, etc., to avoid and prevent related criminal behaviors. In this way, the previously existing congestion during the entry control with the personal entry card, which posed risks to public health, e.g., hotspots for the transmission of COVID-19, is also addressed. Finally, we must inform you that the aforementioned new entry system was chosen after the demand of numerous members, who on the one hand felt intense insecurity regarding unauthorized third parties entering the Club, and on the other hand, were subjected daily to the inconvenience of identification, especially when they forgot their entry card."

Subsequently, the Authority, with document number G/EXE/1441/10-06-2022, called upon N.O.B. to provide additional clarifications regarding, among other things, the documentation of the application of the exception of Article 9 paragraph 2 point a of the GDPR, the technical characteristics of the said system, the relevant technical and organizational security measures that have been implemented, any recipients of the personal data being processed, the time of decision-making for the installation of the system in question and the installation and commencement of the system's operation, and the issue of whether a data protection impact assessment has been conducted regarding the processing's impact on personal data protection. N.O.B., with document number G/ENTRY/8383/29-06-2022, responded again to the Authority that, regarding the legal basis for processing, multiple subparagraphs of Article 6 paragraph 1 and Article 9 paragraph 2 GDPR apply, although it considers that "the said system does not concern sensitive personal data" and clarifies that "our athletes enter through a special entrance only with the magnetic card process, meaning it does not apply to...

5

the said system. The only exception exists when the athlete is a child of a family member, in which case the athlete has also provided their data. Both old and new members have been informed - are being informed (about the said entry system and their right to withdraw) and ultimately provide their explicit consent during the process of capturing their required representations (note: not photographs but representations of distinct geometric features of each person). Specifically, each member (both old and new) must enter the designated area of the Club in order to capture the necessary data for their incorporation into the said system. During this process, the operation of the said entry system as well

as the alternative method of entry into the Club is explained by our qualified staff. After this, the member grants their explicit consent and is immediately informed about the possibility of revoking it. The N.O.B. also states that the applicable sports law requires the maintenance of a membership registry with specific personal data and that any revocation of the said consent for the legally required personal data may lead to the deletion of the member. Furthermore, members, in addition to the above updates, are informed about the alternative method of entry by members of the Board of Directors, the staff of the Club, as well as the security guards at the entrances. To support this, the Club states that all these procedures are also described in the current regulations of the Club and submits the relevant informational forms to the Authority. Regarding the technical specifications of the system, the Club adds that "During the registration process of a new user (enrollment phase), the system collects the coordinates of the geometry of the face. It does NOT photograph and does NOT store photographs of the face. Subsequently, these coordinates are processed by a highly advanced algorithm which creates a code for each user. With this code, the user is linked, and thus all the information recorded in the database of the system is the same as that which would be recorded by an RFID card recognition system, given that NEITHER the algorithm itself can create information that represents a person. That is, at no time does the system photograph and/or video record individuals, whether someone is in front of the identification device or nearby. The retention of the above data applies for as long as the member of the Club is active. The said data is stored on a server at the offices of the Club's secretariat, in a secured area, within the private, fenced, and guarded area of the Club. The following security systems are also active: IDS/IPS & Firewall. The detection of external online threats and attacks is covered by ... with the following services activated until 11/2/2023: a)... b)... c)... d)... e)...., The recipient and responsible for processing is the legal representative of the Club and its president, Ms. B. Regarding the decision to install the controversial system, the Club states that it was unanimously taken by the Board of Directors during the meeting on June 9, 2021, and submits to the Authority the relevant minutes, from which it appears that the project in question was assigned to the company "NousPratIT", while its operational start date is around mid-May 2022.

Finally, the N.O.B. clarifies that no impact assessment study has been conducted for the said system, as it was informed by the collaborating company that this processing is not of high risk to the rights and freedoms of its members, given that it does not involve systematic and extensive evaluation of personal aspects concerning natural persons or large-scale processing or systematic monitoring of publicly accessible space on a large scale.

Moreover, while the process of ex officio inspection of the case mentioned above was initiated, a complaint was submitted to the Authority under protocol number Γ/ΕΙΣ/8072/18-06-2022 by A, whose ... is a member of the N.O.B., and he is her companion, against the N.O.B., in which the complainant states that on 06-04-2022, the members of the Club were informed via email that access to the Club would henceforth be possible only through the use of the new access mechanism utilizing biometric facial characteristics and that the previously operational RFID card entry system would no longer function. The complainant notes that until the introduction of the new system, "entry to the Club was possible either through entry cards for members and their companions (1 companion per member, [...]), or by verifying the identity details of visitors at the entrance and their entry through a process that required the simultaneous physical presence of the member, who would have indicated at the entrance gate the name of the visitor they were expecting. That is, there was verification of the identity of the visitor who had been declared with the person who appeared by presenting their Police Identity Card. Following the...

7

For identification, the visitor was issued an RFID card, which functioned at the corresponding card readers at the entrance/exit turnstiles and was returned by the visitor to the entrance checkpoint upon exit. It is noted that the personalized member and companion identities bear printed information including the member's details (full name), the member number, the card's serial number, and also include a photograph of the holder, so that quick identification by the security personnel of the N.O.B. is possible. Additionally, when the card is read by the entrance card reader, the holder's photograph stored in the Group's records and other card details automatically appear on a nearby screen in the security office. Thus, the validity is ensured and the counterfeiting of the card is prevented, while

allowing for quick (either by presentation from the holder or electronically) confirmation of the holder's identity during entry/exit at the N.O.B. Following the electronic message from the N.O.B. dated 06-04-2022, the complainant and ... sent an electronic statement of opposition to the processing of their personal data regarding the use/processing of any biometric data to the Group on 16-04-2022. On 28-04-2022, the N.O.B. responded electronically only to ... of the complainant regarding the statement of opposition, stating as a reason for the discontinuation of the use of the contactless entry card that it "posed risks to public health" due to crowding during the control of entrants with entry cards and that "for the sake of completeness of this document, we must inform you that any refusal to comply may constitute grounds for the non-retention of your membership status in the Group." The complainant states that the Group never responded to him as the data subject, while regarding the argument about avoiding crowding, he mentions that any "crowding" occurs only from the simultaneous arrival, for example, of two large families, and does not last more than a few seconds for each person's access through the turnstiles, and, because the subject must remain stationary in front of the biometric characteristics reader, the time is identical or perhaps slightly longer compared to the use of an RFID card, and further argues that from the N.O.B.'s response it appears that no alternative method of access (entry/exit) to the Group's facilities is provided, other than the use of biometric characteristics, and any opposition to this processing may constitute grounds for the deletion of the member.

8

Additionally, the complainant states that in the new Operating Regulation of the N.O.B. that came into effect on 04-05-2022, there is no mention of the simultaneous use of entry cards nor has there been any update regarding the rights of the data subjects and their exercise, while only biometric characteristics are exclusively promoted as a means of entry/exit. Furthermore, until mid-May 2022, a letter from the N.O.B. was sent to the parents of children engaged in various activities of the Group, urging them to visit the Group's Secretariat immediately for the renewal of entry cards, as "from Monday, 16 May, they will not function, regardless of financial compliance, due to a change in the access system," meaning that from 16-5-2022 onwards, the only way for entry/exit to the Group for members/companions/family members (children), who until then had personalized entry cards with photographs, is through the use of facial biometric characteristics. The complainant also states that on 09-06-2022, through the Group's electronic newsletter, members were informed that the new system is now required for entry, while visitors of the Group's members can enter at any time they wish into its facilities without any identification, such as by presenting and recording their ID at the entrance and the required additional personal presence of the member, without the necessary simultaneous presence of the member, using a simple combination of numbers (6+7 digits), which is quite easy to leak in any form, such as orally, or cannot be verified for its correct and desired use by the subject/member, putting the security of other individuals identified with biometric characteristics present at immediate risk. Finally, the complainant states that, as several members oppose the use/processing of their biometric characteristics, temporarily the Board of Directors of the N.O.B. accepted and directed the security personnel to allow entry to members who do not wish for their biometric data to be processed to enter alongside, with the mediation of the security personnel (door opening). Entry will be permitted upon presentation of the existing entry card, which can easily and immediately be verified for its validity from the electronic records maintained by the N.O.B., with a terminal (computer) that is online connected to the entrance checkpoint. Specifically, as the complainant asserts, during his visit to the N.O.B. on 13-06-2022, he was asked by the security personnel for identification.

9

of the member and their police identity card for identity verification, even though there is a printed photograph of the member on the entry card. Another example of an obstacle presented to those who do not wish to use biometrics, as stated by the complainant, is that after 8 p.m. there is no staff present at the entrance/exit checkpoint, so if a member wishes to enter at 6 p.m. and wants to exit after 8 p.m., the only alternative is to call an emergency phone number and wait for someone from the staff who is "on call" to come and open the door - which takes at least 45 minutes to 1 hour - while the visitor enters or exits with the simple use of a combination of numbers. The same applies to entering the

premises of the N.O.V. after 8 p.m., as there is no guard present and the previous procedure must be followed, namely the emergency phone number. With the supplementary document No. G/EIS/10657/03-10-2022, the complainant submits to the Authority the initial electronic message dated 06-04-2022 with the electronic newsletter of the N.O.V., in which the Club informs its members, among other things, about the upcoming change in the incoming control system. Specifically, this electronic message states: "The controlled entry-exit system at the N.O.V. has now been modernized with new technologies for the safety and better experience of members. All it takes is 3 minutes of your time to take your biometric characteristics: visit the Secretariat of the N.O.V. to register and then... forget about the card!" Additionally, the complainant informs the Authority that in an announcement posted by the Club on its website on 09-03-2022 regarding the new controlled access system, it is stated, among other things: "The Nautical Club of Vouliagmeni is upgrading its systems with the aim of providing the best possible experience for its Members, athletes, and employees. The controlled access system at the N.O.V. is being modernized, and now the entry of Members and their families is carried out using their biometric characteristics. [...] A visit to the Secretariat of the N.O.V. is all that is required, where all you need to do is look steadily at the special registration screen for 3 seconds in the new system. [...] During this transitional phase until the completion of the transition, the operation of the card from the previous system will continue. However, this will be abolished within the summer, so it is essential that all our Members have registered in the new system to be able to enter the N.O.V. [...] The measurement and coding of the biometric characteristics of facial geometry carried out by the system does not create a file of personal data that could subsequently be reproduced in any way. In this context, your personal data is secure."

Subsequently, the Authority received the complaint No. G/EIS/8648/08-07-2022, as it was supplemented by the document No. G/EIS/8669/08-07-2022, from G, a member of the N.O.V., against the N.O.V., in which he also complains that the new system was introduced without the N.O.V. informing the members that they have the option to choose between the existing electronic card system and that of biometric characteristics, without informing them about the features of the new system, without notifying them that there is the possibility of objection and withdrawal, and without signing the relevant consent document, as well as that the installation of the new system was sudden and caught the members off guard. According to their explicit and absolute statement, at the behest of the President of the N.O.V. and specific members who follow her, the entrance control staff misleadingly forced incoming members to provide their biometric data, "in order to have the ability to enter the N.O.V. from now on," as they continuously stated. No informational sign has been posted, nor has an informative email been sent to the members regarding the necessity of introducing the new system, or for the alternative use of the old system, or for the possibility of withdrawing consent for the processing of biometric data. The complainant states that in the new Operating Regulation of the N.O.V. approved in May 2022, there is no mention of the alternative possibility of using the old incoming control system, but after the documents sent by the Authority to the N.O.V. in June 2022, the Club amended provision 2.1 of the said Regulation as follows: "We remind you that in case of withdrawal of the explicit consent of the Member for the use of their biometric data, they may enter the Club using the identification system with their personal membership card." Finally, the complainant states that members who disagree with the processing of their data by the new system cannot have immediate access to the premises of the N.O.V. at any time they wish, as they cannot enter using the old cards, but are obliged to...

11

They call the supervisor by phone to arrive at the entrance and check their identity and their card in relation to a handwritten list of members who have refused to provide their biometric data, considering this to be particularly unequal treatment, a systematic coercion in violation of the regulations concerning the protection of personal data without any necessity, while there is a perfectly functional electronic card system that allows for the control of those within the N.O.V. simply by presenting the card.

In light of the above, the Authority summoned, with the documents numbered G/EXE/3165/07-12-2022, G/EX/3163/07-12-2022, and G/EX/3164/07-12-2022, i. the N.O.V., as legally represented, ii. the complainant G, and iii. the complainant A, respectively, to attend the plenary

session of the Authority on 13-12-2022, in order to hold a hearing regarding the potential violation of the applicable legislation for the protection of personal data. The aforementioned document also transmitted to the N.O.V. both relevant complaints concerning the case. In this session, the request for postponement submitted by the N.O.V. was discussed, which was accepted by the plenary of the Authority, and a new discussion date was set for 07-02-2023. In this session, the complainants G attended with their attorney Dimitris Kampouramalas (AMDSA ...) and D, who attended to provide information, and A, while on behalf of the N.O.V. were B, President of the Board of Directors of the Group, E, and ST, members of the Board of Directors of the Group along with their attorneys Dimitrios Verbesos (AMDSA ...) and Christina Panagouleas (AMDSA ...), Z, CEO of Atermon Systems S.A., and H, General Director of NousPratiT. After the parties expressed their views, they were given a deadline by the President of the Plenary to submit memoranda.

With the document numbered G/EIS/1780/09-03-2023, the first complainant, supplementing what he had stated during the discussion and in the documents submitted to the Authority, pointed out that from the hearing process and from the assertions of the attorney of the N.O.V., he identified the following significant violations by the Group: i. Violation of the principles of proportionality and necessity of the purpose of processing, given that there are other milder forms of controlled entry. The alternative method of entry for a member who has opposed the contested method of control is the presentation of identification documents that the member carries to the guard at the gate between 8:00 a.m. and 8:00 p.m., and for other hours or when during the winter months the guard is absent for longer hours - the guard - the member must call the on-duty guard from their mobile phone, a time-consuming process compared to the use of the magnetic card. Responding to the claim of the attorney of the N.O.V. regarding the fact that the system was installed to minimize the collected personal data, since the member had to present their identity, the complainant states that identity was never requested, as with the card swipe the member's photo appeared, only if the card had been canceled or was counterfeit, and emphasizes that the simple presentation of an identification document does not constitute the collection of personal data. ii. Violation of Articles 6(1) GDPR and 5(1)(a) and (c) regarding the establishment of the legal basis of legitimate interest for the processing of biometric data. iii. Regarding accountability, the N.O.V., as the data controller, violates Article 37 GDPR, as it has not appointed a Data Protection Officer (hereinafter "DPO") to the Authority, Articles 37(1), 38(3), and 39(1) GDPR, and Directive 243/2016 of the Article 29 Working Party, as the duties of an informal DPO are performed by its President, thus undermining the functional independence of the DPO, Article 57(1)(c) GDPR, and Directive 2016/680, as it did not previously seek the opinion of the Authority to introduce a restriction on the protection of personal data, and finally Articles 35 GDPR, 27 of Directive 2016/680, and 65 Law 4624/2019, as no impact assessment study has been conducted regarding the implications of the contested processing. iv. The N.O.V. does not have the required documentation regarding the contested processing concerning the information provided to its members and the obtaining of relevant consent, as the information provided in the last Internal Regulation is less than what is required by the GDPR, is not in an understandable and easily accessible format, and does not use clear and simple wording, while it has not established a privacy policy and has not posted it on its website. The method of obtaining consent from its members is particularly problematic given the dominant position of the Group over the members, who believe that they will be excluded from entering the Group's facilities if they oppose this processing. Finally, the complainant states that it was declared by the President and the General Secretary, responsibly and in writing, that an alternative functioning card system is in effect, a fact

13

absolutely untrue, because this system has never coexisted with biometric data, and during the discussion before the Plenary of the Authority, the lawyer of N.O.V. clearly admitted that the card did not function alternatively, nor was the necessary information provided prior to the imposition of the new measure. v. The supplying company did not clarify a. what the "facial recognition" of the systems is (the biometric data collected reveals racial origin or health issues, which conflicts with fundamental human rights), b. what guarantees N.O.V. requested and received from the supplying company regarding privacy protection from the design and during the operation of these devices, c. whether any contract was signed for the processing within the framework of the procurement of these systems, and

d. whether the supplying company has been certified with any "privacy seal" or "privacy audit assessment."

With the letter no. Γ/ΕΙΣ/1842/13-03-2023, N.O.V. additionally to what was mentioned during the discussion before the Plenary and in the documents submitted to the Authority, pointed out, with the request to be recognized as permissible and lawful the installation and operation of the ProFace system for the exclusive entry of N.O.V. members, under the terms and conditions that may be dictated by the Authority, that:

i.

There is increased privacy for N.O.V. regarding the subjects to whom the controversial access control system applies, namely because N.O.V. is a sports club and does not engage in commercial and professional activities, and the system under examination processes data of a limited circle of individuals, who chose to have access control performed through facial recognition, as there exists a relationship of trust and familiarity among them, and the processing that takes place is limited, instantaneous, spatially defined, and no third party gains access to it; therefore, this processing, even if it does not fall under the exception of Article 2, paragraph 2(c) of the GDPR (household or personal activity), solely due to the large number of N.O.V. members, should receive legal evaluation considering that this processing meets all the criteria for exemption from the application of the GDPR,

14

ii.

Despite the fact that N.O.V. had a negative financial result for a decade, its revenues in 2022 amount to 3.5 million euros, and all revenues are directed towards covering the operational needs of the Club,

iii.
Because, among other things, there were many past instances of card borrowing and practical inability to verify identity during the summer months, resulting in extremely concerning incidents, such as damage to equipment, uncontrolled presence of unknown individuals in the Club, as in the past the guard recorded the name of a guest indicated by a member or showed their ID without further verification, whereas now each member can use a code for the guests they are entitled to invite and thus bears responsibility for them, the system under review was chosen as more secure for the protection of data and guests. The old system involved the use of an RFID magnetic card, and the member entered through more than one entrance to the Club, showing an identification document that was often not enforced, and when it was enforced, it was ineffective because the photo did not match reality due to its age. For these reasons, it was unanimously chosen, without any reaction from the members, at the Annual General Meeting of the Club's members in March 2022 to install an "access control" system at the entrance of the Club using biometric data of facial geometry for the safety of individuals and facilities. In April 2022, a newsletter was sent to all members to inform them about the installation of the new system, in May 2022 the new Operating Regulation of N.O.V. was sent to the members referencing the use of the new system and the collection of their biometric data, and in June 2022, following the complaint of Mr. A, the relevant article in the Regulation was amended to provide for the possibility of disagreement/revocation of members' consent for the new system,

iv.

Regarding the technical characteristics of the ProFace system by ZKTeco, it is noted that the coordinates of each face create a unique code through a highly advanced algorithm, and the device does not recognize faces or biometric characteristics each time a member enters but recognizes the code, and the measurement and encoding of biometric characteristics do not...

15

creates a personal data file in the system that could be reproduced in some way. Additionally, the software complements the aforementioned system from a security perspective and has been installed alongside ProFace on a different server from the one serving the rest of the Group's IT infrastructure, which is the software "Soft1 ERP," used for the commercial-accounting IT organization of the members and from which the ZKTeco system extracts information, such as whether a member is financially up-to-date in order to allow them entry, in the following manner: A member is created in the ERP (their details, billing information, which group they belong to - whether they are a member or a guest or

other), with a photograph of the individual, from which the financial record of each member arises, and if they are financially up-to-date, the ERP informs ProFace that they are allowed entry. The ERP also contains the cards of visitors with a specific number of entries, while each financially up-to-date member is entitled to 2 cards. Each individual is registered in the ERP and receives a 6-digit code, and the user updates a flag field if they want this 6-digit code to be opened in the ZKTeco system, and the member is registered in ZKTeco with the same 6-digit code. The ERP is updated only with the number of entries made by the members' visitors using the cards. The access rights of each individual are managed by N.O.B. Therefore, the ERP, as N.O.B. asserts, has no relation whatsoever to ProFace, nor is the encrypted code used for identification recorded/stored/archived anywhere in the ERP.

v.

The data controller of the biometric identification system is N.O.B. and there is no processor, as N.O.B. states, the company NousPratiT that installed the system provides ad hoc support services when a technical issue arises and only gains access to the encrypted data of ProFace. The DPO of N.O.B. has been appointed as the Chairperson of the Group's Board of Directors, while the Group intends to contract with a certified DPO. The subjects whose data are processed by the new access control system are the members and their companions, totaling 3,500, while employees, visitors/fans, athletes, and restaurant patrons continue to use other systems and enter through other entrances. Recipients of any data, and regarding the biometrics exclusively of the unique code, are the salaried employees of the secretariat, who have access only to the encrypted data and the reports generated by the ProFace application. Assuming that there is no processing of biometric data by the ProFace entry control system, the legal basis for the processing is Article 6, paragraph 1, point a of the GDPR, as members signed a consent form upon registration, which explicitly states both their rights and the possibility of revocation. Additionally, N.O.B. has a legitimate interest in protecting persons and assets under its responsibility, which is based on point f of paragraph 1 of Article 6 of the GDPR, while assuming that there is processing of special category data, Article 9, paragraph 2, point a of the GDPR applies.

vi.

The processing of data is governed by the principles of legality because it has a legal basis, objectivity and transparency because there is full information about the system, proportionality because the data are the most appropriate, necessary, and relevant for the intended purpose, as after weighing, the system in question was preferred with the least possible interference in the privacy of the members, in contrast to other proposed technological solutions, such as the use of fingerprints.

vii.

Regarding technical and organizational measures, it is noted that concerning physical security, the rack is located in a configured computer room, the backup of the files of the Windows server 2008 R2 is encrypted and is performed only for the shared files of the Group, and the historical data due to volume is retained for 7 days and the data are kept on 2 external drives, which the General Director regularly alternates.

viii. Since N.O.B. seeks further compliance, it has commissioned a Data Impact Assessment Study and whatever the outcome, it is committed to taking it into account and adjusting, if necessary, its technical and organizational measures. Already from the conduct of the hearing, it has initiated procedures to contract the company "GDPR Greece IKE" for the project of obtaining ISO27001 certification, namely the certification for the management of information security.

17

of information and personal data processed within the Group.

The Authority, after examining the contents of the file, having heard the presenter and the clarifications from the assistant presenters, who attended without voting rights, following a thorough discussion,

CONSIDERED IN ACCORDANCE WITH THE LAW

1. Since, from the provisions of Articles 51 and 55 of the General Data Protection Regulation (EU) 2016/679 (hereinafter "GDPR") and Article 9 of Law 4624/2019 (Government Gazette A'137), it follows that the Authority has the competence to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal

data.

2. Since, according to the definitions of Article 4, point 1 of the GDPR, "personal data means any information relating to an identified or identifiable natural person ('data subject'); ..." and point 14 defines biometric data as "personal data resulting from specific technical processing related to physical, physiological or behavioral characteristics of a natural person, which allow or confirm the unequivocal identification of that natural person, such as facial images or fingerprint data."

3. Since biometric data falls under the special categories of personal data, which are generally prohibited from being processed, according to Article 9, paragraph 1 of the GDPR: "The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, as well as the processing of genetic data, biometric data for the purpose of uniquely identifying a person, data concerning health or data concerning a person's sex life or sexual orientation is prohibited." Paragraph 2 of the same article provides for exceptions to the above prohibition, the first of which is the explicit consent of the data subject. Specifically, it is stated: "Paragraph 1 shall not apply in the following cases: a) the data subject has given explicit consent to the processing of those personal data for one or more specific purposes, unless Union or Member State law provides that the prohibition referred to in paragraph 1 cannot be lifted by the data subject, [...]"

4. Since Article 5 of the GDPR establishes the principles of processing that govern the processing of personal data. Specifically, it is stated in paragraph 1 that personal data shall, among other things: "a) be processed lawfully and fairly in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency'). b) be collected for specified, legitimate, and explicit purposes and not further processed in a manner that is incompatible with those purposes (...), c) be adequate, relevant, and limited to what is necessary for the purposes for which they are processed ('data minimization') (...), e) be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ('integrity and confidentiality')", and in paragraph 2 that "the data controller shall be responsible for, and be able to demonstrate compliance with, the principles of processing set out in paragraph 1 ('accountability')." In order for personal data to be processed lawfully, i.e., processed in accordance with the requirements of the GDPR, the conditions for the application and adherence to the principles of Article 5, paragraph 1 of the GDPR must be cumulatively met. The collection and processing of personal data must always take place in light of the principles of proportionality and necessity, and the data controller, in the context of its adherence to the principle of fair or lawful processing of personal data, must inform the data subject that it intends to process their data in a lawful and transparent manner and must be able to demonstrate compliance with these principles at any time. Also, as the Authority has already ruled, with the GDPR a new compliance model was adopted, the central point of which is the principle of accountability, within which the data controller is obliged to design, implement, and generally take the necessary measures and policies to ensure that the processing of

3 See Authority Decisions 36/2021, para. 3, 26/2019, para. 8, 44/2019, para. 19, available on its website.

19

data to be in compliance with the relevant legislative provisions. Furthermore, the data controller bears the specific duty to demonstrate and prove at any time its compliance with the principles of Article 5(1) GDPR, both to the data subject for reasons of transparency of processing and, in particular, before the supervisory authority. It is not coincidental that the GDPR incorporates accountability (Article 5(2) GDPR) into the regulation of the principles (Article 5(1) GDPR) governing processing, endowing it with the function of a mechanism for their compliance, essentially reversing the "burden of proof" regarding the legality of processing (and generally the adherence to the principles of Article 5(1) GDPR), shifting it to the data controller, so that it can be reasonably argued that they bear the burden of invoking and proving the legality of the processing. Thus, it is an obligation of the data controller, on the one hand, to take the necessary measures to comply with the requirements of the GDPR, and on the other hand, to demonstrate at any time their aforementioned compliance, without the need for the Authority, in

exercising its investigative and supervisory powers, to submit specific detailed questions and requests to ascertain compliance.

5. Because, as clarified in Recital 51 of the GDPR, special categories of data require special protection, as the context of their processing could create significant risks to fundamental rights and freedoms. Therefore, while the processing of "ordinary" personal data is lawful if one of the legal bases of Article 6 applies, the processing of special categories of data is, in principle, prohibited and allowed only if cumulatively one of the legal bases of Article 6 and one of the exceptions of Article 9(2) GDPR apply.

6. Because the existence of a legal basis (Article 6 GDPR) does not exempt the data controller from the obligation to adhere to the principles (Article 5(1) GDPR) regarding the legitimate nature, necessity, proportionality, and the principle of data minimization. In the event that any of the principles set out in Article 5(1) GDPR is violated, the processing in question is deemed unlawful (subject to the provisions of the GDPR) and the examination of the conditions for applying the legal bases of Article 6 GDPR becomes unnecessary. Thus, the unlawful collection and processing of personal data in violation of the principles of Article 5 GDPR is not remedied by the existence of a lawful purpose and legal basis (cf. DPA 38/2004).

7. Because, according to Article 35(1) GDPR: "when a type of processing, particularly using new technologies and taking into account the nature, scope, context, and purposes of the processing, is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall, prior to the processing, carry out an assessment of the impact of the intended processing operations on the protection of personal data. An assessment may consider a set of similar processing operations that present similar high risks." The Authority, in application of paragraph 4 of Article 35 GDPR, with its decision 65/2018, has drawn up and published a list of the types of processing operations that are subject to the requirement for conducting a data protection impact assessment under paragraph 1. Among these operations are included the following:

"1.2 Systematic processing of data aimed at making automated decisions that produce legal effects concerning the data subjects or significantly affect the data subjects in a similar manner and may lead to exclusion or discrimination against the natural person (...).

1.3 Systematic processing of data that may prevent the data subject from exercising their rights or using a service or contract, particularly when considering data collected from third parties (...).

2.1 Large-scale processing of special categories of data (including genetic and biometric data for the purpose of unequivocally identifying a person) referred to in Article 9(1) and the data referred to in Article 10 of the GDPR.

3.1 Innovative use or application of new technologies or organizational solutions, which may include new forms of data collection and use, with a potential high risk to the rights and freedoms of natural persons such as the...

6 Official Gazette B' 1622/10-5-2019

7 Cf. Decision DPA 65/2018 available on the Authority's website.

21

Combined use of fingerprints and facial recognition for enhanced physical access control, or mhealth applications or other "smart" applications, from which user profiles are created (e.g., daily habits), or artificial intelligence applications or publicly accessible blockchain technologies that include personal data.

8. Whereas, according to the Guidelines 3/2019 of the EDPB:

"73. The use of biometric data, and in particular facial recognition, poses increased risks to the rights of data subjects. These technological means must necessarily be used in accordance with the principles of legality, necessity, proportionality, and data minimization as provided for in the GDPR. Although the use of these technologies may be considered particularly effective, data controllers must first assess the impact that these technological means have on fundamental rights and freedoms and consider the use of less intrusive means to achieve the legitimate purpose of processing. 74. The processing of raw data such as the physical, biological, or behavioral characteristics of a natural person, to be classified as the processing of biometric data as defined in the GDPR, must indicate measurement of these characteristics. Since biometric data is the result of such measurements," the

definition of the GDPR in Article 4(14) applies, as stated above, "However, video footage depicting individuals cannot be considered as biometric data per se according to Article 9, unless the material has previously undergone specific technical processing in order for this processing to contribute to the identification of individuals." 75. The processing of biometric data, to be regarded as processing of special categories of personal data (Article 9), must have "the purpose of the indisputable identification of a person."

76. In summary, in light of Article 4(14) and Article 9, three criteria must be taken into account:

- Nature of the data: data related to the physical, biological, or behavioral characteristics of a natural person,
- Means and method of processing: data that "arises from specific technical processing,"
- Purpose of the processing: the data must be used for the purpose of the indisputable identification of a natural person.

77. The use of video surveillance systems that include biometric recognition functions installed by private entities for their own purposes (e.g., for commercial promotion, statistical purposes, or even security) often requires the explicit consent of all data subjects (Article 9 paragraph 2 point a)), although in this case, another legal exception of Article 9 may also apply.

9. Whereas, according to the case law of the Court of Justice of the European Union, "as stated in Recital 39 of the GDPR, the requirement of necessity is not met when the pursued purpose of general interest can reasonably be achieved in an equally effective manner by other means that are less intrusive to the fundamental rights of data subjects, particularly the rights to respect for private life and to the protection of personal data enshrined in Articles 7 and 8 of the Charter, taking into account that exceptions and limitations regarding the principle of protection of such data must not exceed what is strictly necessary" and "the requirement of necessity of processing must be examined together with the so-called principle of 'data minimization,' which is established by Article 6, paragraph 1, point c of Directive 95/46, as well as Article 5, paragraph 1, point c of the GDPR, according to which personal data must be adequate, relevant, and limited to what is necessary for the purposes for which they are processed." This decision essentially accepts that processing is lawful only for necessary data.

10. Whereas, in the Advocate General's proposals of 06-10-2022 submitted in the context of the proceedings leading to the Court's decision of 04-05-2023 in case C-300/2021, it is stated, among other things, that "73. The consent of the data subject, as the highest expression of control, is only one of the legal bases for lawful processing, but it is not sufficient to validate non-compliance with the other obligations and conditions that burden the data controller and the...

23

processing. 74. In my opinion, it is not easy to conclude from the GDPR that its purpose is to provide the data subject with control over personal data as an independent value. Nor that the data subject should have the maximum possible control over such data. 75. This finding is not surprising. On the one hand, it is not obvious whether control, in the sense of ownership of the data, is part of the substantive content of the fundamental right to the protection of personal data. On the other hand, the recognition of this right as a right to informational self-determination is far from unanimous: Article 8 of the Charter does not use these terms. 76. For the same reason, the final text of the GDPR did not include any recitals stating that "the right to the protection of personal data is based on the right of the data subject to exercise control over the personal data being processed."

11. Because, regarding the data protection officer, according to Article 38(3) of the GDPR, "The controller and the processor ensure that the data protection officer does not receive instructions regarding the exercise of those tasks. He or she shall not be dismissed or subjected to any other penalties by the controller or the processor for having performed his or her tasks. The data protection officer shall report directly to the highest management level of the controller or the processor," paragraph 5 "The data protection officer is bound by the obligation of secrecy or confidentiality with regard to the performance of his or her tasks, in accordance with Union or Member State law," and paragraph 6 "The data protection officer may also perform other tasks and duties. The controller or the processor shall ensure that such tasks and duties do not result in a conflict of interest." Furthermore, in the Guidelines of the Article 29 Working Party 2911, it is stated that "the data protection officer cannot hold a position within the organization from which he or she can determine the purposes and means of

processing personal data. Since each organization has a different organizational structure, this specific issue should be examined on a case-by-case basis."

11 Guidelines on Data Protection Officers of the Article 29 Working Party, WP 243 rev.01, Chapter 3.5

24

12. Because, in the case under consideration, from the file elements, the hearing of the parties involved, as well as the submitted memoranda, it appears that:

i. The N.O.B., according to the "Operating Regulation of N.O.B. for Members - 2022," has installed and operates, at least since mid-May 2022, at the entrance of its facilities a "biometric identification system," as it characterizes it, which identification system is based on facial geometry that is unique to each individual. For the operation of this system, the data subject must enter the specific area of N.O.B. to undergo the required imaging of distinct geometric features of each individual. The system collects the coordinates of the facial geometry, which are processed through an algorithm that creates a code for each user, and the aforementioned data are stored digitally on the server of N.O.B. for as long as the data subject is an active member of the Group.

Therefore, the Authority finds that with this identification system for entrants, processing of special categories of personal data is taking place, and N.O.B. becomes the data controller of these.

ii. At the time the complaints were filed against N.O.B., the members of N.O.B. did not have the option to use another entry system into the Group, apart from the system under examination, as for some time, this was the only means of entry for them.

iii. In the "Operating Regulation of N.O.B. for Members - 2022," submitted by N.O.B. with its letter No. Γ/ΕΙΣ/8383/29-06-2022, it is stated that "For entry into N.O.B. of Members (main and protected), biometric characteristics are used. After their registration in the biometric system, plastic cards are canceled. [...] We remind you that in case of withdrawal of the explicit consent of the Member for the use of their biometric data, they may enter the Group using the identification system with their personal membership card." However, in the available document during the same period addressed to the members of N.O.B. "Information Document for New Members, regarding their personal data," information is provided about the processing of personal data, without reference to the data that...

25

They are processed with the biometric system under examination and on the legal basis of consent for special category data. In the memorandum submitted to the Authority by N.O.V. following the hearing before the Plenary, with reference number Γ/ΕΙΣ/1842/13-03-2023, it was presented the "Consent Form for the Pro Face Biometric Identification System as Access Control Method at N.O.V.", which states that "It is expressly assured by the Group that the biometric/geometric data of the face (and not imaging data) used for recognition/identification are not collected in a file, nor stored on a computer unit" and "I expressly declare that I have been INFORMED about the processing of biometric data taking place by the Nautical Club of Vouliagmeni and I CONSENT to the said processing," and a relevant selection field is provided for the data subject. Finally, in the email response dated 28-04-2022 from N.O.V. to the first complainant, following their statement of objection dated 16-04-2022 regarding the processing of their personal data, it was stated that "any refusal to comply [i.e., to grant consent for the new entry system] may constitute a reason for the non-maintenance of your membership status in the Club."

iv.

The data subjects whose data are processed with the new access control system are the members and their companions, totaling 3,500, while employees, visitors/fans, athletes, and restaurant patrons continue to use other systems and enter through other entrances.

v.

Regarding the impact assessment, N.O.V.'s initial response to the Authority was that it deemed the preparation of such an assessment unnecessary, while after the hearing before the Plenary, N.O.V. informed the Authority that it has commissioned the conduct of this study and whatever the outcome, it is committed to take it into account and to adjust, if necessary, the technical and organizational measures it has already implemented. N.O.V. has not submitted an impact assessment for the system under examination to the Authority.

vi.

N.O.V. has appointed the Chairperson of the Board of Directors of the Group as the Data Protection Officer.

26

13. Because, in light of the above, the Authority finds that N.O.V. has installed and put into operation the biometric characteristics system under examination, for which, as indicated in the above paragraph 12.i., the processing of special category personal data of the subjects is required, and N.O.V. becomes the data controller of these. This processing relates to the systematic processing of data using new technology and automated processing of data, with a potential high risk to the rights and freedoms of natural persons (facial recognition), as it involves large-scale processing of special categories of data concerning approximately 3,500 subjects, as it pertains to all members of the Group and their companions. From the case file, it appears that the data controller has not documented that the use of the new system is necessary and proportionate, and in particular that milder forms of controlled access to the premises, using simple data processing, are not feasible for the purpose of processing. Furthermore, for some time, it implemented the said biometric characteristics system without providing appropriate information to the subjects regarding the processing of their data, without obtaining their consent, and without providing an alternative method of controlled access. Therefore, since it was not documented, based on the principle of accountability (Article 5(2) GDPR), by the data controller, who is obliged to demonstrate compliance with the principles of Article 5(1) GDPR, the necessity of the purpose of this processing, the principle of legality (Article 5(1)(a)) has been violated, and the processing of special category personal data in question is deemed unlawful. According to what is stated in paragraph 6, the examination of the existence of a legal basis for processing under Article 6 of the GDPR and the application of exceptions to the prohibition of processing special categories of personal data under Article 9(2) GDPR is unnecessary.

14. Because, although, according to what is stated in paragraph 7, N.O.V. as the data controller had an obligation, under Article 35(3)(c) GDPR and the aforementioned Decision 65/2018 of the Authority, to conduct an impact assessment.

12 See i. Guidelines for the impact assessment regarding data protection (EAPD) determining whether the processing "may result in a high risk" for the purposes of Regulation 2016/679, WP No. 29 WP 248 rev. 01, ii. Opinion 7/2018 EDPB, and iii. Decision 65/2018 EDPB "List of types of processing operations subject to the request for conducting an impact assessment regarding data protection according to Article 35(4) GDPR."

27

Regarding the protection of special categories of data, it did not document before the Authority, in accordance with the principle of accountability (Article 5(2) GDPR), its compliance with this obligation, the violation of which constitutes a separate infringement under Article 35 of the GDPR.

15. Because, according to the GDPR and the Guidelines of the EDPB 2913, the Data Protection Officer (hereinafter "DPO") must perform their duties independently and therefore cannot hold a position within the data controller from which they can determine the purposes and means of processing personal data. In this specific case, the Chairperson of the Board of Directors of N.O.V., as the legal representative of the data controller, determines the purposes and means of processing personal data, and by assigning the DPO duties to herself, objective oversight of compliance with the GDPR is not ensured. Therefore, according to the aforementioned Guidelines, the position of the Chairperson of the Board of Directors is in substantial conflict of interest and is incompatible with the position of DPO, and consequently, the coincidence of these two roles in the same person contradicts the provision of Article 38(3) of the GDPR.

16. Because, based on the above, the Authority considers that there is a case to exercise its corrective powers to impose fines under Articles 58(2)(h) and 83 of the GDPR regarding the aforementioned identified violations, as well as the corrective powers under Article 58(2)(d) and (f) in order to impose on the data controller the obligation to conduct a data protection impact assessment for the processing of personal data of the subjects through the system under examination and to cease this processing until the assessment is conducted. For the determination of the fines, in order to be effective,

proportionate, and deterrent, the criteria for measuring fines set out in Article 83(2) of the GDPR that apply in this case are taken into account, as they have been specifically interpreted by the EDPB Guidelines 4/2022 for the calculation of administrative fines.

17. Because, in evaluating the data, the Authority particularly considers:

13 See above footnote 11.

14 https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under_en - version 2.1

28

- i. the nature and gravity of the infringement, which concerns the fundamental principles of lawfulness of processing that are essential for the protection of personal data, according to the GDPR, taking into account that, regardless of the fact that compliance with the principles set out in Article 5 of the GDPR is of paramount importance, primarily, the principle of lawfulness, so that if it is absent, the processing becomes unlawful from the outset, even if the other processing principles have been adhered to; in this case, it was found that unlawful processing occurred using the system under examination,
- ii. that the processing in question concerns special categories of personal data of a large number of subjects,
- iii. that the data controller considered the possibility of conducting a data protection impact assessment and decided that it was not required,
- iv. the fact that the violation of the provisions regarding the fundamental principles for processing falls under, according to the provisions of Article 83(5)(a) and (b) of the GDPR, the highest category of the administrative fines system,
- v. that the revenue of N.O.V. amounts to 3.5 million for the year 2022.

Based on the above, the Authority unanimously decides that administrative sanctions, as mentioned in the operative part, should be imposed on the reported Group, as the data controller, which are deemed proportionate to the severity of the violations.

FOR THESE REASONS

The Authority

A. Imposes on the Nautical Club of Vouliagmeni, as the data controller, based on Article 58(2)(h) of the GDPR, a fine of twenty-eight thousand euros (€28,000) for the violation of the principle of lawfulness (Article 5(1)(a) GDPR).

B. Imposes on the Nautical Club of Vouliagmeni, as the data controller, based on Article 58(2)(h) of the GDPR, a fine of fourteen thousand euros (€14,000) for the failure to conduct a data protection impact assessment of the biometric access control system (Article 35 GDPR).

C. Imposes on the Nautical Club of Vouliagmeni, as the data controller, on the one hand, based on Article 58(2)(d) of the GDPR, to conduct, in accordance with Article 35 GDPR, a data protection impact assessment of the processing operations through the biometric access control system regarding the protection of personal data, and on the other hand, based on Article 58(2)(f) of the GDPR, to cease the processing of personal data through the aforementioned biometric access control system until it conducts the data protection impact assessment as mentioned above and to inform the Authority regarding the above actions, no later than three (3) months from the notification of this decision.

D. Imposes on the Nautical Club of Vouliagmeni, as the data controller, based on Article 58(2)(h) of the GDPR, a fine of fourteen thousand euros (€14,000) for the violation of Article 38(3) of the GDPR.

The President

The Secretary

Konstantinos Menoudakos

Irini Papageorgopoulou